Sécurité des sites gouvernementaux gabonais (`.gouv.ga`)

Rapport défensif générique — classes de vulnérabilités & durcissement de la pile WordPress / Joomla / PHP

Version 1.0 — 23 octobre 2026 · Document de travail interne
Portée : guide défensif générique, non ciblé · Public visé : administrateurs, DCSI ministérielles, ANINF, prestataires mandatés

> **Avertissement de portée et d'usage.** Ce document est un **guide défensif générique**. Il décrit des *classes* de vulnérabilités et des mesures de durcissement applicables à la pile technique (WordPress, Joomla, PHP, serveur web) couramment utilisée par les sites `.gouv.ga`. Il ne contient **aucune instruction d'exploitation** ni aucune cartographie de failles exploitables visant un site nommé. Toute recherche active de vulnérabilités (scan, test d'intrusion) sur un système tiers exige une **autorisation écrite préalable** du propriétaire de l'actif. Les références à des domaines précis (annexe A) constituent un **inventaire d'actifs à protéger** pour leur exploitant, et non une invitation à les attaquer.

1. Résumé exécutif

Les sites publics gabonais en `.gouv.ga` (portail, ministères, secrétariat général) ainsi que le portail `gouvernement.ga` reposent très majoritairement, d'après des empreintes publiques, sur des **systèmes de gestion de contenu écrits en PHP** — principalement **WordPress** et **Joomla** — conçus et déployés par un atelier commun (l'ANINF). Cette homogénéité est une force pour la gouvernance (durcissement standardisable) mais aussi un risque systémique : *une même faiblesse peut toucher tout le parc*.

Les priorités défensives, par ordre d'impact et de simplicité de mise en œuvre :

Priorité	Action structurante	Risque couvert
P0	Mettre à jour le noyau CMS et **toutes** les extensions/thèmes ; retirer ceux inutilisés	Composants vulnérables connus
P0	Authentification forte des comptes d'administration (MFA, mots de passe robustes, suppression des comptes génériques)	Prise de contrôle de compte
P1	HTTPS strict + en-têtes de sécurité + limitation de débit sur les pages de connexion	Interception, force brute
P1	Supprimer les fichiers exposés (sauvegardes, `.git`, `phpinfo`, pages de debug) et désactiver le listing de répertoires	Fuite d'information
P2	Sauvegardes testées + journalisation centralisée + supervision + plan de réponse	Résilience & détection

2. Contexte technique

Inventaire et empreinte technologique proviennent de sources publiques (moteurs de recherche, structure des URL, profils de technologies publics). Deux constats établis :

- **Pile PHP/CMS dominante.** `gouvernement.ga` fonctionne sous WordPress ; `primature.gouv.ga` sous Joomla. Les autres sites ministériels, issus du même atelier, sont très probablement sur la même famille (à confirmer par l'exploitant).
- **Homogénéité du parc.** L'ANINF indique avoir réalisé des dizaines de sites ministériels et institutionnels. Un modèle de déploiement commun permet un durcissement « une fois, appliqué partout ».

> **Pourquoi les CMS gouvernementaux sont des cibles fréquentes :** forte visibilité, confiance du public, contenus sensibles, et surtout un *cycle de mise à jour souvent en retard* sur des plateformes (WordPress/Joomla) dont les failles d'extensions sont publiées en continu.

3. Classes de vulnérabilités courantes (vue défensive)

Chaque classe est décrite par son origine, son impact et les mesures de réduction du risque. Aucune procédure d'exploitation n'est fournie.

3.1 Composants tiers obsolètes — Critique

Origine : extensions, plugins, modules et thèmes non mis à jour. C'est la **première cause** de compromission des sites WordPress/Joomla : les failles sont publiées et des codes d'exploitation circulent peu après la publication des correctifs.

Impact : exécution de code, création de comptes admin, défiguration, hébergement de contenu malveillant.

Mesures : inventaire exhaustif des extensions ; mise à jour régulière ; **désinstallation** (pas seulement désactivation) de tout composant inutile ; n'installer que des extensions maintenues et de source officielle ; suivre les bulletins de sécurité (Joomla VEL, bases de vulnérabilités WordPress).

3.2 Noyau CMS non mis à jour — Critique

Origine : version majeure/mineure du CMS en retard (ex. branches Joomla ou WordPress non maintenues).

Impact : exposition à des failles corrigées depuis longtemps.

Mesures : rester sur une branche supportée ; activer les mises à jour mineures automatiques quand c'est possible ; planifier les montées de version majeures avec recette préalable.

3.3 Authentification & gestion des accès — Critique

Origine : mots de passe faibles ou réutilisés, absence de double authentification (MFA), comptes génériques/partagés, comptes de test oubliés, pages d'administration ouvertes sans limitation de tentatives.

Impact : prise de contrôle d'un compte à privilèges, donc du site entier.

Mesures : MFA obligatoire pour tout compte à privilèges ; politique de mots de passe robustes ; un compte nominatif par personne, principe du moindre privilège ; suppression des comptes inutilisés ; limitation du débit et temporisation sur la connexion ; restriction d'accès à la console d'administration (filtrage IP/VPN quand c'est opérationnellement possible).

3.4 Mauvaise configuration & exposition de fichiers — Élevée

Origine : listing de répertoires activé, fichiers de sauvegarde (`.zip` , `.sql`) laissés dans la racine web, dossier `.git` exposé, `phpinfo()` , pages de debug, fichiers de configuration lisibles.

Impact : fuite d'identifiants, de code source, de données — souvent le point de départ d'une compromission.

Mesures : désactiver le listing de répertoires ; sortir sauvegardes et dépôts de la racine web ; supprimer `phpinfo` /pages de debug en production ; refuser l'accès aux fichiers sensibles côté serveur ; `display_errors=Off` en production.

3.5 Entrées non validées : injections, XSS, upload — Élevée

Origine : données utilisateur insuffisamment validées/échappées (injection SQL, XSS, inclusion de fichiers, upload de fichiers non contrôlé). Concerne surtout les extensions tierces et le code sur mesure.

Impact : vol de données, exécution de code, détournement de session.

Mesures (développement sûr) : requêtes préparées/paramétrées ; validation stricte en liste blanche ; échappement contextuel en sortie ; contrôle du type et du contenu des fichiers téléversés, stockage hors racine web ; politique de sécurité de contenu (CSP) ; pare-feu applicatif (WAF) en complément, jamais en remplacement du correctif.

3.6 Transport, TLS & en-têtes de sécurité — Élevée

Origine : HTTP non redirigé vers HTTPS, versions TLS obsolètes, certificats mal gérés, absence d'en-têtes de sécurité.

Impact : interception, vol de session, injection de contenu.

Mesures : HTTPS partout + redirection ; TLS 1.2/1.3 uniquement ; renouvellement automatisé des certificats ; en-têtes `HSTS`, `Content-Security-Policy`, `X-Content-Type-Options`, `Referrer-Policy`, `X-Frame-Options` / `frame-ancestors`.

3.7 Sessions & cookies — Moyenne

Mesures : cookies `Secure`, `HttpOnly`, `SameSite` ; régénération d'identifiant de session à l'authentification ; expiration raisonnable ; déconnexion effective.

3.8 Chaîne d'approvisionnement & thèmes « nulled » — Élevée

Origine : extensions/thèmes piratés ou de source non vérifiée, souvent porteurs de portes dérobées.

Mesures : sources officielles uniquement ; vérification d'intégrité ; revue avant mise en production ; interdiction formelle des thèmes/extensions « nulled ».

3.9 Sauvegardes, journalisation & détection — Moyenne

Origine : absence de sauvegardes testées, de journaux exploitables et de supervision.

Impact : incapacité à détecter, à investiguer et à restaurer après incident.

Mesures : sauvegardes régulières, hors ligne, **restaurées à blanc périodiquement** ; journaux centralisés (web, auth, CMS) ; alertes sur événements sensibles ; plan de réponse à incident écrit.

4. Checklist de durcissement priorisée

P0 immédiat P1 court terme P2 moyen terme

4.1 WordPress

Prio.	Mesure
P0	Noyau, thèmes et extensions à jour ; suppression de l'inutilisé ; mises à jour mineures automatiques.
P0	MFA sur tous les comptes ; supprimer le compte `admin` générique ; rôles au moindre privilège.
P1	Limiter les tentatives de connexion ; protéger la page de connexion ; désactiver l'éditeur de fichiers de l'admin (`DISALLOW_FILE_EDIT`).
P1	Désactiver l'API d'énumération et XML-RPC si inutiles ; bloquer l'exécution PHP dans `uploads`.
P2	Durcir `wp-config.php` (clés, permissions) ; plugin de sécurité/monitoring de réputation.

4.2 Joomla

Prio.	Mesure
P0	Noyau sur branche supportée ; extensions à jour ; vérifier chaque extension contre la liste des extensions vulnérables (VEL).
P0	MFA activé ; renommer/protéger l'accès `/administrator` ; comptes nominatifs.
P1	Activer le secret d'URL sur l'administration ; forcer HTTPS pour l'admin ; permissions de fichiers correctes.
P2	Désactiver l'inscription publique si inutile ; revue des overrides de templates.

4.3 PHP & serveur web (Apache/Nginx)

Prio.	Mesure
P0	Version PHP supportée ; `display_errors=Off` , `expose_php=Off` en production.
P1	Désactiver le listing de répertoires ; interdire l'accès aux fichiers sensibles ; retirer sauvegardes/ `.git` / `phpinfo` de la racine web.
P1	En-têtes de sécurité (HSTS, CSP, X-Content-Type-Options, Referrer-Policy, frame-ancestors) ; TLS 1.2/1.3 seulement.
P2	WAF en amont ; limitation de débit ; durcissement OS (ex. référentiels CIS, audit Lynis).

4.4 Organisation & exploitation

Prio.	Mesure
P0	Sauvegardes régulières et **testées** (restauration à blanc) ; copies hors ligne.
P1	Journalisation centralisée + supervision + alertes ; plan de réponse à incident.

P2	Cadence de patch définie ; inventaire des actifs et des responsables ; sensibilisation des contributeurs.

5. Auto-diagnostic légitime (sur ses propres actifs)

> **Condition impérative :** n'utiliser ces outils que sur des sites dont on est propriétaire ou pour lesquels on détient une autorisation écrite. Respecter les conditions d'utilisation des services tiers.

Besoin	Outils légitimes
Identifier CMS & versions	`whatcms.org`, `builtwith.com`, consoles d'administration du CMS
Audit WordPress (son site)	WPScan (avec jeton), tableau de bord « Santé du site »
Audit Joomla (son site)	Outils de maintenance Joomla, vérification VEL, services de supervision dédiés
Qualité TLS	Qualys SSL Labs
En-têtes de sécurité	`securityheaders.com`, Mozilla Observatory
Durcissement serveur/OS	Lynis, référentiels CIS Benchmarks

6. Gouvernance (ANINF / DCSI ministérielles)

- **Standardiser le durcissement** dans l'image/modèle commun de déploiement — levier majeur vu l'homogénéité du parc.
- **Politique de mises à jour** : cadence, fenêtres de maintenance, responsabilités (qui patche quoi, quand).
- **Inventaire vivant** des sites, versions, extensions et responsables.
- **Supervision centralisée** et détection des défigurations/compromissions.
- **Politique de divulgation responsable (VDP)** et point de contact sécurité (idéalement adossés à un CERT national), pour recevoir et traiter les signalements externes.
- **Recette sécurité** avant mise en ligne (revue de code et de configuration des sites sur mesure).

7. Références

- OWASP Top 10 ; OWASP ASVS (exigences de vérification applicative)
- WordPress — « Hardening WordPress » (documentation officielle)
- Joomla — « Security Checklist » & Vulnerable Extensions List (VEL)
- CIS Benchmarks (serveurs web, OS) ; outil d'audit Lynis
- Guides d'hygiène de sécurité et recommandations d'un CERT/ANSSI de référence
- Qualys SSL Labs ; Mozilla Observatory ; securityheaders.com

Annexe A — Parc d'actifs à protéger (inventaire)

Inventaire défensif. La colonne « CMS / PHP » provient d'empreintes publiques et **doit être confirmée par l'exploitant** (en-têtes HTTP, balise generator). Voir le script `scripts/check-ga-php.sh` du dépôt.

Domaine	Entité	CMS / PHP (empreinte publique)
gouvernement.ga	Portail Gouvernemental	WordPress (PHP) — confirmé par empreinte
primature.gouv.ga	Primature	Joomla (PHP) — confirmé par empreinte
sgg.gouv.ga	Secrétariat Général du Gouvernement	CMS PHP probable — à confirmer
budget.gouv.ga	Économie, Finances, Dette et Participations	CMS PHP probable — à confirmer
diplomatie.gouv.ga	Affaires Étrangères	CMS PHP probable — à confirmer
interieur.gouv.ga	Intérieur, Sécurité, Décentralisation	CMS PHP probable — à confirmer
travail.gouv.ga	Travail, Plein Emploi, Dialogue Social	CMS PHP probable — à confirmer
fonction-publique.gouv.ga	Fonction Publique	CMS PHP probable — à confirmer
sante.gouv.ga	Santé	CMS PHP probable — à confirmer
agriculture.gouv.ga	Agriculture, Élevage, Développement Rural	CMS PHP probable — à confirmer
petrole.gouv.ga	Pétrole et Gaz	CMS PHP probable — à confirmer
enseignement-superieur.gouv.ga	Enseignement Supérieur & Recherche	CMS PHP probable — à confirmer
transports.gouv.ga · mines.gouv.ga · justice.gouv.ga · economie-numerique.gouv.ga · education-nationale.gouv.ga	Autres ministères (à revérifier)	À confirmer
presidence.ga · assemblee-nationale.ga · journal-officiel.ga	Institutions (hors `.gouv.ga`)	À confirmer
e-tax.dgi.ga · edgdi.dgdi.ga · ecnamgs.cnamgs.ga · cnss.ga · tresorpublic.ga	Téléservices (applications métier)	Langage non déductible — à

		confirmer
